**Lab 3: Advanced GRC Phishing Simulation & Quantitative Risk Analysis**

**Student Name:** Nolusindiso Sonjani
**Student Number:** C112617560
**Course:** GRC103
**Lab:** 3
**Date:** 29 October 2026

**1. Lab Data Set**

**PHASE 1: BASIC METRIC CALCULATIONS**

**Step 1: Calculate Fundamental Rates**

Formula: Rate = (Number of Events / Number of Emails Sent) × 100*

**YOUR TURN: Fill in the blanks**

| Campaign | Email Open Rate | Click-Through Rate | Credential Submission Rate | Data Entry Rate |
|---|---|---|---|---|
| **A** | (82/100)×100 = 82% | (47/100)×100 =47**%** | (18/100)×100 = 18**%** | (5/100)×100 = 5% |
| **B** | (200/250)×100 = 80**%** | (150/250)×100 = 60**%** | (75/250)×100 = 30**%** | (25/250)×100 = 10**%** |
| **C** | (72/80)×100 = 90% | (60/80)×100 = 75**%** | (12/80)×100 = 15% | (8/80)×100 = 10% |

**Step 2: Calculate Efficiency Metrics**

*How effective is each step of the attack?*

**Conversion Rate from Open to Click:**

- Campaign A: (47/82)×100 **= 57.3%**
- Campaign B: (150/200)×100 = 75**%**
- Campaign C: (60/72)×100 = 83.3**%**

**Post-Click Credential Submission Rate:**

- Campaign A: (18/47)×100 = **38.3%**
- Campaign B: (75/150)×100 =**50%**
- Campaign C: (12/60)×100 = **20%%**

**PHASE 2: ADVANCED RISK QUANTIFICATION**

**Step 3: Calculate Organizational Risk Exposure**

**Scaled Risk Projection:**
*If these rates apply to our entire organization of 2,000 employees...*

**For Campaign B (most successful):**

- Expected Credentials Stolen: 2,000 × (75/250) = **600 employees**
- Expected Data Breaches: 600 × 25% probability = **150 breaches**

**CALCULATION:**

- Campaign B Credential Rate: 75/250 = 30%
- Organization Exposure: 2,000 × 0.30 = **600 employees**
- Expected Breaches: 600 × 0.25 = **150 breach incidents**

**Step 4: Financial Impact Analysis**

**A. Calculate Potential Financial Loss:**

- Single Breach Cost: $4,350,000
- Expected Number of Breaches: 150
- Total Exposure: $4,350,000 × 150 = **$652,500,000**

**B. Calculate Annualized Loss Expectancy (ALE):**
*ALE = Single Loss Expectancy × Annual Rate of Occurrence*

- Single Loss Expectancy (SLE): $4,350,000
- Annual Rate of Occurrence (ARO): 150 expected breaches
- ALE = $4,350,000 × 150 = **$652,500,000**

**Step 5: Control Effectiveness Analysis**

**MFA Cost-Benefit Analysis:**

- Cost = **$90,000**
- Risk Reduction=**$651,847,500**
- ROI= **724,175%**

**Security Training Cost-Benefit:**

- Cost = **$100,000**
- Risk Reduction= **$391,500,000**
- ROI: = **391,400%**

**PHASE 3: COMPREHENSIVE RISK ASSESSMENT**

**Step 6: Complete Risk Assessment Matrix**

| Campaign | Overall Risk Score | Financial Exposure | Priority Level | Recommended Action |
|---|---|---|---|---|
| **A** | MEDIUM-HIGH | $156,600,000 | 2 | Enhanced Training |
| **B** | **CRITICAL** | **$652,500,000** | **1** | **IMMEDIATE MFA** |
| **C** | HIGH | $104,400,000 | 2 | Executive Training |

**CALCULATIONS FOR TABLE:**

- Campaign A Exposure: (18/100)×2000 = 360 employees × 0.25 × $4,350,000 = $156,600,000
- Campaign C Exposure: (12/80)×2000 = 300 employees × 0.25 × $4,350,000 = $104,400,000

**Step 7: Statistical Significance Analysis**

**Calculate Confidence Intervals (95% Confidence):**
Formula: $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$*

**For Campaign B Credential Rate (30%):**

- p = 0.30, n = 250
- Margin of Error = $1.96 \times \sqrt{[0.30(1-0.30)/250]} = 1.96 \times \sqrt{(0.21/250)} = 1.96 \times \sqrt{0.00084} = 1.96 \times 0.029 = 0.057$
- **True Rate Range: 24.3% to 35.7%**

**YOUR TURN: Calculate for Campaign A:**

- p = 0.18, n = 100
- Margin of Error = $1.96 \times \sqrt{[0.18(1-0.18)/100]}$ =7.5%?
- True Rate Range: 10.5% % to 25.5%

**PHASE 4: EXECUTIVE REPORTING**

**Step 8: Comprehensive Executive Briefing**

**To:** Board of Directors, CISO, CFO
**From:** GRC Risk Analysis Team
**Date:** 29 October 2026
**Subject:** CRITICAL: Quantitative Phishing Risk Assessment & $652M Exposure

**1. Executive Summary**

Our phishing simulation analysis identified a critical cyber risk exposure of approximately $652.5 million annually. The highest-risk campaign, "IT Password Reset," achieved a 30% credential theft rate, indicating that approximately 600 employee accounts could be compromised if a real-world phishing attack occurred.

The analysis demonstrates that the organization faces a 93.75% probability of experiencing a major phishing-related breach, resulting in substantial financial, operational, regulatory, and reputational impacts. Immediate implementation of recommended security controls is strongly advised.

**2. Key Quantitative Findings:**

| Risk Metric | Value | Industry Average | Severity |
|---|---|---|---|
| Overall Credential Theft Rate | 22.1% | 15.3% | HIGH |
| Maximum Campaign Success Rate | 30% | 18.7% | CRITICAL |
| Annualized Loss Expectancy | $652M | $285M | SEVERE |
| MFA Implementation ROI | 724,175% | 350% | EXCELLENT |

**3. Detailed Financial Analysis:**

**Current Risk Profile**

| Metric | Value |
|---|---|
| Annualized Loss Expectancy (ALE) | **$652,500,000** |
| Expected Major Breaches | **150** |
| Probability of Major Breach | **93.75%** |
| Per-Employee Risk Exposure | **$326,250** |

## Business Impact Summary

- Estimated compromised accounts: **600**
- Average breach impact: **$4,350,000**
- Projected annual financial exposure: **$652.5M**
- Current phishing susceptibility exceeds industry benchmark by **6.8%**

**Proposed Security Investment Portfolio:**

| Control | Cost | Risk Reduction | Net Benefit | ROI | Priority |
|---|---|---|---|---|---|
| MFA Implementation | $90,000 | $651.8M | $651.7M | 724,175% | **1** |
| Enhanced Training | $100,000 | $391.5M | $391.4M | 391,400% | **2** |
| Email Filtering | $50,000 | $130.5M | $130.4M | 260,800% | **3** |

**4. Strategic Recommendations:**

**IMMEDIATE ACTIONS (Q1):**

**1. Implement Enterprise-Wide MFA**

- Investment: **$90,000**
- Expected reduction in credential compromise risk: **90%**
- Highest ROI among evaluated controls

**2. Launch Targeted Phishing Simulations**

- Investment: **$25,000**
- Focus on high-risk departments
- Improve employee detection rates

**3. Emergency Security Awareness Training**

- Investment: **$100,000**
- Prioritize employees who failed phishing simulations
- Monthly awareness campaigns

**5. Strategic Initiatives (FY2027)**

**1. Advanced Email Security Gateway**

- Investment: **$50,000**
- Reduce phishing email delivery and exposure

**2. Continuous Security Monitoring**

- Investment: **$150,000**
- Rapid detection of compromised credentials

**3. Security Behavior Analytics**

- Investment: **$75,000**
- Identify anomalous user activity
- Detect account compromise before escalation

**6. Expected Risk Posture After Controls:**

| Metric | Current | With Controls | Reduction |
|---|---|---|---|
| Credential Theft Rate | 22.1% | 2.2% | 90% |
| Annual Loss Expectancy | $652M | $65M | 90% |
| Breach Probability | 93.75% | 25% | 73.3% |

**7. Investment Summary**

| Item | Amount |
|---|---|
| Total Security Investment | **$490,000** |
| Total Risk Reduction | **$587,500,000** |
| Net Financial Benefit | **$587,010,000** |

**Executive Conclusion**

The proposed security investment represents less than **0.1%** of the current annual exposure while reducing organizational phishing risk by approximately **90%**. MFA deployment provides the greatest risk reduction and should be executed immediately.

**Bonus Challenge: Break-Even Analysis**

**Formula**

Break-Even Point=Total Control CostLoss per Breach\text{Break-Even Point} = \frac{\text{Total Control Cost}}{\text{Loss per Breach}}Break-Even Point=Loss per BreachTotal Control Cost =$490,000$4,350,000= \frac{\$490,000}{\$4,350,000}=$4,350,000$490,000 =0.1126= 0.1126=0.1126

**Result**

**Break-even Point = 0.11 breaches**

This means the organization only needs to prevent **approximately one-tenth of a single breach** to recover the entire security investment.

**Management Interpretation**

- Preventing just one breach saves approximately $4.35 million.
- The proposed investment of $490,000 pays for itself after preventing only 11.26% of one breach event.
- Therefore, the business case for implementing the recommended controls is overwhelmingly positive.